17.4 Authorization before retrieval: making RAG safe by construction

As ACME began experimenting with retrieval-augmented generation (RAG) systems, the architectural boundary that ensured authorization decisions are made by the policy engine and not by the AI became an important safety requirement.

RAG systems combine a language model with external data sources to retrieve documents or records, grounding generated responses in enterprise data. While this approach can dramatically improve the relevance and usefulness of responses, it also introduces a subtle but serious risk. RAG makes retrieval the point where context enters the model. If retrieval is not constrained by authorization, unauthorized data can be put in the prompt before any safeguards apply.

ACME learned that the only reliable way to prevent this class of failure is to enforce authorization before retrieval. Instead of asking the language model to decide what information is appropriate, the system must first determine which data is allowed to be retrieved at all. Only authorized data is ever placed into the model's context. This makes the system safe by construction, eliminating reliance on prompt discipline or model behavior.

17.4.1 A quick review of how RAG works

Retrieval-augmented generation (RAG) provides a language model with application- or domain-specific documents and data. Rather than relying solely on the model's internal parameters, a RAG system retrieves relevant information at runtime and injects it into the prompt used to generate a response.

In a RAG architecture

- Application- or domain-specific and data documents are broken into chunks and converted into vector embeddings.
- Those chunks are stored in a vector database, typically alongside metadata such as document identifiers, ownership, classification, or